

DGA Capital Management LP — Information Security & Incident Response Policy

Entity: DGA Capital Management LP (single-family office)

Scope: The DGA Capital portfolio/research application (web + mobile) and its backend, including data received from the Plaid API.

Owner / Security contact: Alec Mazo, General Partner — alecmazo1@gmail.com

Last reviewed: 2026-06. Reviewed at least annually and after any material change.

1. Governance

The General Partner is responsible for information security. The application is an internal tool used solely by the GP to manage the family office's own and family-managed accounts. There are no external/consumer users.

2. Access control (least privilege)

- All application access requires authentication. User passwords are hashed with PBKDF2-HMAC-SHA256 (200,000 iterations, per-user random salt); plaintext passwords are never stored. There is no shared or master ("god-mode") password.
- Role-based authorization: financial/account data is restricted to the GP/admin role; limited-partner accounts can see only their own fund data.
- Production console access (hosting and source control) is restricted to the GP and protected by multi-factor authentication.
- Application secrets (signing keys, encryption keys, third-party API keys) are stored only in the hosting provider's encrypted environment variables — never in source code or the client. Missing/weak secrets fail closed (the app refuses to operate with default values).

3. Encryption

- **In transit:** TLS 1.2+ for all client–server and server–database traffic.
- **At rest:** the database volume is encrypted at rest by the hosting provider.

In addition, Plaid access_tokens are encrypted at the application layer (AES via Fernet) with a key held separately from the database, so a database copy alone cannot expose them.

4. Credential handling

End-user financial-institution credentials are **never** received or stored.

Account linking uses Plaid Link with the institution's OAuth flow; credentials are entered on the institution's own page.

5. Vulnerability & patch management

- The backend runs on a managed platform that patches the underlying OS/runtime.
- Application dependencies are version-pinned; automated dependency vulnerability

alerts (e.g., GitHub Dependabot) are enabled on the source repository.

- Developer endpoints use OS automatic updates and disk encryption.

6. Logging & monitoring

An audit log records authentication and sensitive actions. Tokens and PII are redacted from logs; account numbers are stored only as the last-4 mask.

7. Data retention & deletion

- Plaid-sourced data is retained only while the corresponding account connection

is active.

- A connection can be removed on demand, which revokes the access token at Plaid

(/item/remove) and purges the stored data for that connection.

- Retention/deletion practices are reviewed at least annually for compliance with

applicable data-privacy laws.

8. Incident response

1. **Detect** — monitor logs/alerts for unusual access or failures.

2. **Contain** — revoke affected Plaid tokens, rotate signing/encryption secrets, and disable affected access.

3. **Notify** — notify affected data subjects and Plaid as required.

4. **Remediate** — patch the root cause and document the incident.

The GP is the incident responder; reachable at alecmazo1@gmail.com.